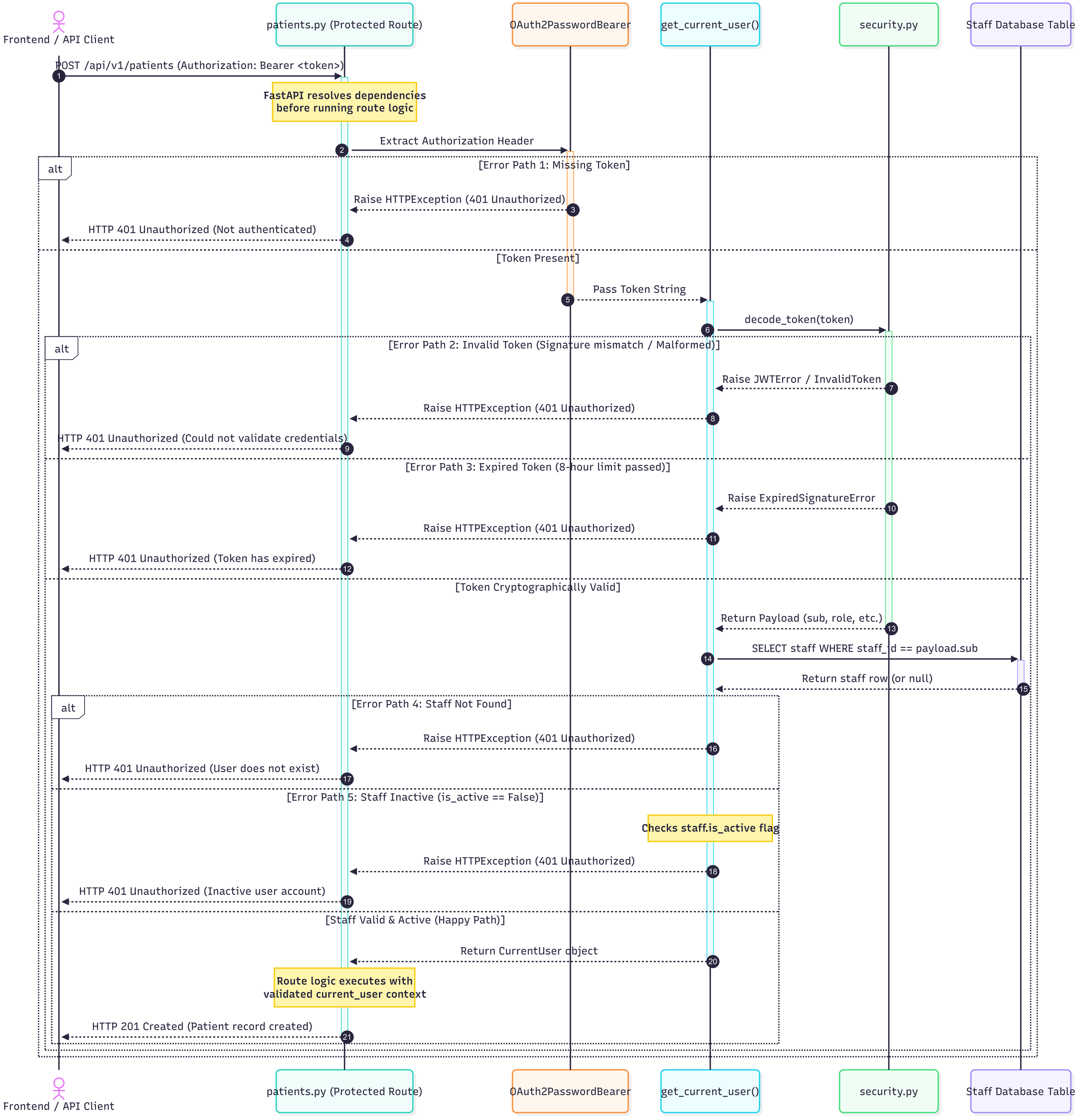

Frontend / API Client
patients.py (Protected Route)
OAuth2PasswordBearer
get_current_user()
security.py
Staff Database Table
POST /api/v1/patients (Authorization: Bearer <token>)
1
FastAPI resolves dependencies before running route logic
Extract Authorization Header
2
alt
[Error Path 1: Missing Token]
Raise HTTPException (401 Unauthorized)
3
HTTP 401 Unauthorized (Not authenticated)
4
[Token Present]
Pass Token String
5
decode_token(token)
6
alt
[Error Path 2: Invalid Token (Signature mismatch / Malformed)]
Raise JWTError / InvalidToken
7
Raise HTTPException (401 Unauthorized)
8
HTTP 401 Unauthorized (Could not validate credentials)
9
[Error Path 3: Expired Token (8-hour limit passed)]
Raise ExpiredSignatureError
10
Raise HTTPException (401 Unauthorized)
11
HTTP 401 Unauthorized (Token has expired)
12
[Token Cryptographically Valid]
Return Payload (sub, role, etc.)
13
SELECT staff WHERE staff_id == payload.sub
14
Return staff row (or null)
15
alt
[Error Path 4: Staff Not Found]
Raise HTTPException (401 Unauthorized)
16
HTTP 401 Unauthorized (User does not exist)
17
[Error Path 5: Staff Inactive (is_active == False)]
Checks staff.is_active flag
Raise HTTPException (401 Unauthorized)
18
HTTP 401 Unauthorized (Inactive user account)
19
[Staff Valid & Active (Happy Path)]
Return CurrentUser object
20
Route logic executes with validated current_user context
HTTP 201 Created (Patient record created)
21
Frontend / API Client
patients.py (Protected Route)
OAuth2PasswordBearer
get_current_user()
security.py
Staff Database Table